

CLOUDORA

B2B HR Software | Security Operations

SECURITY INCIDENT REPORT

Report ID	CLD-IR-0001
Related ticket	CLD-0001 - Suspicious sign-in activity: daniel.reeve@cloudora.io
Report title	Executive account takeover via password spray, with MFA persistence and BEC staging
Analyst	Adithyan V, SOC Analyst - Cloudora engagement (MyFirstHack training)
Date of report (UTC)	2026-08-10
Incident severity	P1 - executive mailbox compromised during an active enterprise deal; fraud staging in place
Status	Contained - eradication verified, monitoring continues
Classification	CONFIDENTIAL - Internal and client distribution only

1. Executive summary

Between 8 and 10 August 2026, an external attacker ran a low-volume password guessing campaign against 26 Cloudora staff accounts from three IP addresses in Lagos, Nigeria. In the early hours of 10 August the attacker guessed the correct passwords for two accounts: the CEO (Daniel Reeve, 03:12 UTC) and a second staff member (Priya Nair, 03:47 UTC).

On the CEO account, the attacker registered their own authentication device and created a hidden email rule that diverts finance- and invoice-related mail - the standard setup for invoice fraud against Cloudora's customers.

The compromise was detected the same morning, both accounts were contained, the attacker's device and email rule were removed, and the attacker's network addresses were blocked.

No evidence of data theft or fraudulent payment was found in the available logs; 24 further accounts that were targeted but not breached have been flagged for precautionary password resets.

2. Incident timeline

All times UTC. Sources: CloudoraSignIn_CL (sign-in logs), CloudoraAudit_CL (audit logs).

Time (UTC)	Source	Event
Aug 08, 00:00-05:00	Sign-in	Password spray night 1: 44 failed sign-ins from 102.89.x.x IPs across ~20 accounts (1-3 attempts each)
Aug 09, 00:00-05:00	Sign-in	Password spray night 2: 36 failed sign-ins, same source IPs, same low-and-slow pattern
Aug 10, 00:35:48	Sign-in	Spray night 3 begins; failed attempt against daniel.reeve from 102.89.44.17
Aug 10, 03:09:12	Sign-in	Failed sign-in, daniel.reeve, 102.89.44.17 (Lagos), ResultType 50126
Aug 10, 03:10:41	Sign-in	Failed sign-in, daniel.reeve, 102.89.44.17, ResultType 50126
Aug 10, 03:12:05	Sign-in	SUCCESSFUL sign-in, daniel.reeve, 102.89.44.17, Windows 10 / Chrome

Time (UTC)	Source	Event
		125 - initial access (T1078)
Aug 10, 03:14:30	Sign-in	daniel.reeve mailbox accessed via Outlook Web from 102.89.44.17
Aug 10, 03:18:44	Audit	Attacker registers own authenticator app on daniel.reeve, device 'Pixel 6' - MFA persistence (T1098.005)
Aug 10, 03:26:02	Sign-in	daniel.reeve session opens Azure Portal from 102.89.44.17
Aug 10, 03:31:09	Audit	Inbox rule 'RSS Subscriptions' created on daniel.reeve: mail from finance@cloudora.io or containing 'invoice' moved to RSS Feeds and marked read - BEC staging (T1564.008)
Aug 10, 03:44:55	Sign-in	Failed sign-in, priya.nair, 102.89.45.101
Aug 10, 03:47:18	Sign-in	SUCCESSFUL sign-in, priya.nair, 102.89.45.101 - second account compromised
Aug 10, 03:52:40	Sign-in	priya.nair session accesses SharePoint Online from 102.89.45.101
Aug 10, 08:41:00	Sign-in	Daniel Reeve's genuine sign-in from London (203.0.113.11, macOS/Safari) - account in use from two countries 5.5 hours apart
Aug 10, 08:55	Ticket	IT admin flags impossible travel on the CEO account; ticket CLD-0001 raised, investigation starts
Aug 10, ~10:30	Response	Containment executed on both accounts (see section 7)

3. Findings

Finding 1 - The CEO account was accessed by an attacker, not by Daniel travelling

daniel.reeve@cloudora.io authenticated successfully at 03:12:05 UTC on 10 Aug from 102.89.44.17 (Lagos, Nigeria) on a Windows 10 / Chrome 125 device never seen on this account before. The success was immediately preceded by failed attempts at 03:09 and 03:10 and followed by mailbox access (Outlook Web, 03:14) and Azure Portal access (03:26). The account's 8-day baseline is exclusively United Kingdom (39 London sign-ins); Daniel signed in normally from London at 08:41 the same morning on his usual macOS/Safari device. Travel and VPN are excluded by the failure pattern, the 3AM timing, the unfamiliar device fingerprint, and the same-day London activity.

Finding 2 - Initial access came from a three-night password spray, not phishing

The three Lagos IPs generated 114 failed sign-ins (ResultType 50126) across 26 distinct accounts between 8 and 10 Aug, concentrated between 00:00 and 05:00 UTC, with only 1-3 attempts per account per night: 102.89.44.17 (48 failures, 23 accounts), 102.89.45.101 (38 failures, 20 accounts), 102.89.44.23 (28 failures, 18 accounts). This low-and-slow, many-accounts pattern is password spraying (T1110.003), designed to stay under account lockout thresholds.

Finding 3 - The attacker established MFA persistence on the CEO account

At 03:18:44, six minutes after initial access, the audit log records 'User registered security info' on daniel.reeve from 102.89.44.17: an authenticator app on device 'Pixel 6' (T1098.005). With their own MFA method registered, the attacker would survive a password reset - which is why credential reset alone was not treated as containment.

Finding 4 - A BEC inbox rule was staged for invoice fraud

At 03:31:09 the attacker created inbox rule 'RSS Subscriptions' on the CEO mailbox: any mail from finance@cloudora.io or containing 'invoice' is moved to the RSS Feeds folder and marked read (T1564.008). This hides finance conversations from the mailbox owner so the attacker can run invoice fraud from the CEO's identity

undetected. No outbound fraudulent mail was observed in the available logs; the rule was staged but, on current evidence, not yet used.

Finding 5 - A second account, priya.nair, was compromised the same night

priya.nair@cloudora.io was successfully accessed from 102.89.45.101 at 03:47:18 after a failed attempt at 03:44:55, followed by SharePoint Online access at 03:52:40. Her baseline is 33 London sign-ins from 203.0.113.10 with no prior foreign activity. No persistence actions appear in the audit log for this account, but the same containment steps were applied (see section 7).

Finding 6 - omar.farah's Dubai activity is legitimate travel (false positive, cleared)

omar.farah@cloudora.io shows 12 sign-ins from Dubai (185.93.245.66) across 8-10 Aug. All are daytime (09:00-19:00), all succeed first try with zero failures, and all come from his usual iOS 17 / Mobile Safari device seen throughout his London baseline. This is consistent travel, not compromise. Note: Omar was also among the 26 spray-targeted accounts (6 failed Lagos attempts against him, none successful), so he is cleared as a victim but still gets a precautionary reset.

4. Indicators of compromise (IOCs)

Type	Value	First seen (UTC)	Context
IPv4	102.89.44.17	Aug 08, ~00:00	Lagos, NG. Spray source; CEO initial access, MFA registration, inbox rule
IPv4	102.89.44.23	Aug 08, ~00:00	Lagos, NG. Spray source (28 failures, 18 accounts)
IPv4	102.89.45.101	Aug 08, ~00:00	Lagos, NG. Spray source; priya.nair compromise
Device fingerprint	Windows 10 / Chrome 125	Aug 08	Consistent attacker fingerprint on all 102.89.x.x activity
MFA device name	'Pixel 6' (authenticator app)	Aug 10, 03:18:44	Attacker-registered MFA on daniel.reeve - removed
Inbox rule name	'RSS Subscriptions'	Aug 10, 03:31:09	BEC mail-hiding rule on daniel.reeve - deleted

5. MITRE ATT&CK mapping

Tactic	Technique ID	Technique name	Evidenced by
Credential Access	T1110.003	Brute Force: Password Spraying	Finding 2 - 114 failures, 26 accounts, 3 nights, 3 IPs
Initial Access	T1078	Valid Accounts	Findings 1 and 5 - successful logins with sprayed credentials
Persistence	T1098.005	Account Manipulation: Device Registration	Finding 3 - attacker authenticator 'Pixel 6'
Defense Evasion	T1564.008	Hide Artifacts: Email Hiding Rules	Finding 4 - inbox rule 'RSS Subscriptions'

6. Scope

Accounts confirmed compromised (2)

daniel.reeve@cloudora.io (03:12:05 UTC) and priya.nair@cloudora.io (03:47:18 UTC), both 10 Aug, both from 102.89.x.x attacker infrastructure, evidenced by successful sign-ins in CloudoraSignIn_CL.

Accounts targeted but not breached (24)

The spray targeted 26 distinct accounts; excluding the two breached accounts, 24 received failed attempts only and require precautionary password resets:

alba.vega, amelia.frost, aria.reid, cole.burke, dina.said, emma.hayes, ethan.wells, freya.lynn, gwen.muir, isla.grant, joel.kerr, jude.ross, kian.patel, leah.stone, lena.voss, liam.doyle, mira.shah, nina.cole, omar.farah, rhys.owen, ruth.dean, ryan.boyd, seth.lane, sofia.marino (all @cloudora.io)

Accounts investigated and cleared (1)

omar.farah@cloudora.io - Dubai sign-ins assessed as legitimate travel (Finding 6). Remains in the reset list above as a spray target.

7. Actions taken

Executed morning of 10 Aug (UTC), in order. In this training scenario these are the documented response decisions; in a live tenant each row would carry the operator and change ticket.

Order	Action	Why this order matters
1	Revoked all active sessions and refresh tokens for daniel.reeve and priya.nair	Kills live attacker sessions immediately; a reset without revocation leaves existing sessions working
2	Reset credentials for both compromised accounts	New credentials only matter once old sessions are dead
3	Removed attacker MFA method 'Pixel 6' from daniel.reeve; reviewed priya.nair MFA methods (no attacker method found)	With attacker MFA in place the account is NOT clean after a reset - this is the back door
4	Deleted inbox rule 'RSS Subscriptions' from daniel.reeve mailbox; audited both mailboxes for further rules	Removes the BEC staging; rules persist independently of credentials
5	Blocked 102.89.44.17, 102.89.44.23, 102.89.45.101 via Conditional Access / named locations	Cuts the known attacker infrastructure off from the tenant
6	Verified: re-ran Step 1 and Step 5 queries - no 102.89.x.x activity after containment; forced re-authentication on both accounts	Containment is a claim until you prove it in the logs

8. Recommendations

- Force password resets for the 24 targeted-but-not-breached accounts listed in section 6 - the spray may have come closer than the logs show.
- Require MFA on all accounts and disable legacy authentication protocols that bypass it; two accounts fell to password-only guessing.

- Alert on new MFA method registration and new inbox rules for executive accounts - both attacker persistence actions were loggable but unmonitored.
- Deploy a password-spray detection rule (failures per IP across distinct accounts in a rolling window) - this attack was visible from night one, two days before the breach.
- Review Conditional Access: block or step-up authentication from countries with no business presence.
- Brief the finance team on BEC risk before the enterprise deal closes: verify any payment-detail change by phone on a known number.

9. Lessons learned

Detection relied on a human noticing impossible travel five and a half hours after initial access; a basic spray rule would have alerted on night one, roughly 51 hours earlier.

The audit log turned a password incident into the real story - without it, containment would have missed the MFA back door and the BEC rule.

Scoping past the first victim found the second account within minutes of the same query.

Baseline comparison (Daniel vs Omar) prevented both a missed detection and a false accusation, and belongs in every identity investigation.

End of report CLD-IR-0001. Training artefact - Cloudora is a fictional company; all data is synthetic.